

USB Baiting — Attack Vector Assessment

Rhetorical Hospital | Security Team Activity

Scenario

A member of the Rhetorical Hospital security team discovered a USB stick on the parking lot ground bearing the hospital's logo. The device was brought inside, connected to a virtual environment for safe inspection, and found to belong to Jorge Bailey, the hospital's Human Resource Manager. The following analysis documents the device's contents, potential attacker exploitation vectors, and recommended risk controls.

Activity Template — Completed

Category	Analysis
Contents	The USB drive belonging to Jorge Bailey contains a mixture of personal and work-related files. Personal items include family photo folders, pet pictures, vacation planning documents, and a wedding invitation. Work-related files include a new hire letter, employee shift schedules, an annual budget tracker, and what appears to be a professional resume for an HR Employment Manager role. Many of these files contain personally identifiable information (PII) — such as employee names, schedules, salary data, and personal contact details — that could be exploited if the device fell into the wrong hands.
Attacker Mindset	An attacker who obtained this device would gain access to sensitive HR and financial data that could be used to craft highly convincing spear-phishing emails targeting Jorge, his family members, or hospital staff listed in the employee directory. The shift schedules and new hire letter reveal internal organizational structure, which an attacker could exploit to impersonate HR staff and manipulate employees into disclosing credentials or granting unauthorized access. Additionally, the attacker could have pre-loaded malware onto the device before planting it, using the hospital logo as social engineering bait to encourage an unsuspecting employee to plug it into a hospital workstation, potentially establishing a backdoor into the hospital network.
Risk Analysis	USB baiting attacks pose serious technical, operational, and managerial risks to healthcare organizations. From a technical standpoint, infected USB drives can introduce ransomware, keyloggers, or remote access trojans (RATs) that spread across the hospital network — potentially disrupting patient care systems. Operationally, the exposure of HR records and financial data could lead to identity theft, regulatory violations (e.g., HIPAA breaches), and reputational damage. To mitigate these risks, the hospital should: (1) implement technical controls such as USB port blocking via endpoint management software and mandatory antivirus scanning of any external media; (2) establish operational policies requiring all found devices to be reported to IT security rather than connected to any workstation; and (3) deliver recurring security awareness training educating staff on USB baiting tactics and the importance of keeping personal and business storage devices separate.

Key Takeaways

- Even without malicious code, a found USB drive is a significant security incident due to the PII it may contain.
- USB baiting relies on human curiosity — employee training is one of the most effective mitigations.
- Technical controls (USB port restrictions, endpoint protection) should complement policy and training.
- Healthcare organizations face elevated risk due to the sensitivity of HR, payroll, and patient-adjacent data.